

Risk Register - (ISO 31000)											
Risk ID	Date Identified	Risk Description /Scenario	Root Cause/ Threat	Potential Consequence/Impact	Likelihood (1-5)	Impact (1-5)	Risk Score (LxI)	Risk ID	Date Identified	Risk Description /Scenario	Risk ID
R-011	2026-05-18	Employees using unauthorized free AI tools (e.g., ChatGPT Free tier) for drafting company documents	Free AI tools may retain and reuse user input for model training (Data vulnerability).	Leakage of confidential corporate data, intellect property, or proprietary information, leading to compliance breaches and reputational damage.	4	4	16	High	IT Security Manager/ GRC Analyst	Deploy enterprise AI solution with data privacy agreements (DPA).	Risk Taxonomy: understanding how to properly categorize threats, vulnerabilities, and consequences using standardized, non-technical language.
R-012	2026-05-18	Employees using unauthorized free AI tools (e.g., ChatGPT Free tier) for drafting company documents	Free-tier generative AI Tools may retain and store user submitted text inputs for model training process	Proprietary company communication and protected information (PII) could leak publicly or appear in AI outputs for other users triggering catastrophic GDPR fines.	4	4	20 (formula)	High	IT Security Manager/ GRC Analyst	Block access to unauthorized public AI domains via corporate firewall policies and migrate staff to enterprise-licensed AI tools with signed data processing agreements (DPAs) that data guarantee privacy.	Risk Register Maintenance: Learning to quantify abstract operational behaviors into a structured format that executives can use to allocate budgets and approve security controls
R-013	2026-05-18	Employees using unauthorized free AI tools (e.g., ChatGPT Free tier) for drafting company documents	Public generative AI models can experience "hallucinations" (generating false or fabricated facts) and lack clinical training accuracy verification.	An over reliance on a faulty AI-generated summary, leading to loss of intellectual properties, compliance violations, unauthorized disclosure and financial penalties.	3	3	9	Low	IT Security Manager/ GRC Analyst	Implement mandatory, documented human in the loop validation for all AI-assisted documentation and deploy a specialized, FDA-compliant clinical AI summarization tool that cites its records.	Risk Mitigation, Risk Management, Compliance safeguards, and AI output validation Frameworks.